

ระบบตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

นายพรชัย กอประเสริฐถาวร

นายลาภบุญเอก กมลพิมุกต์

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2548

ระบบตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

นายพรชัย กอประเสริฐถาวร

นายลาภบุญเอก กมลพิมุกต์

อาจารย์ที่ปรึกษา

อ.อัครเดช วัชรภพพงษ์

ผศ.ธนา หงษ์สุวรรณ

อ.ธนัญชัย ตรีภาค

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2548

ปริญญานิพนธ์ปีการศึกษา 2548

ภาควิชา วิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

เรื่อง ระบบตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

Incident Response System

ผู้จัดทำ

1. นายพรชัย กอประเสริฐถาวร รหัสประจำตัว 45010495

2. นายลาภบุญเอก กมลพิมุกต์ รหัสประจำตัว 45010496

(อาจารย์อัครเดช วัชรเทพวณิช) อาจารย์ที่ปรึกษา

(ผู้ช่วยศาสตราจารย์ธนา หงษ์สุวรรณ) อาจารย์ที่ปรึกษา

(อาจารย์ธนัญชัย ศรีภาค) อาจารย์ที่ปรึกษา

ระบบตอบสนองเมื่อเกิดการละเมิดความปลอดภัย

นายพรชัย กอประเสริฐถาวร	45010495
นายลาภบุญเอก กมลพิมุกด์	45010496
อาจารย์อัครเดช วัชรระภูพงษ์	อาจารย์ที่ปรึกษา
ผศ.ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษาร่วม
อาจารย์ธัญชัย ศรีภาค	อาจารย์ที่ปรึกษาร่วม
ปีการศึกษา 2548	

บทคัดย่อ

ถึงแม้ระบบรักษาความปลอดภัยทางคอมพิวเตอร์จะดีเลิศเพียงใด ก็ยังมีโอกาสเกิดการละเมิดได้ ฉะนั้นระบบรักษาความปลอดภัยทางคอมพิวเตอร์ที่ดีจึงต้องเตรียมความพร้อมต่อเหตุการณ์ดังกล่าว ทั้งก่อนหน้า ระหว่าง และหลังเกิดการละเมิดความปลอดภัย เพื่อทราบได้ว่าเกิดการละเมิดขึ้นแล้ว การทำอะไรไปบ้าง กระทบต่อสิ่งใดบ้าง และจะทำการกู้คืนระบบให้สามารถทำงานเช่นเดิมได้อย่างไร รวมถึงการรวบรวมหลักฐานเพื่อเอาผิดต่อผู้ละเมิดความปลอดภัย

โครงงานนี้เป็นโครงงานใหม่ที่มุ่งศึกษาแนวทางการตอบสนองเมื่อเกิดการละเมิดความปลอดภัยในทุกช่วงเหตุการณ์ โดยเน้นระบบปฏิบัติการยูนิกซ์

INCIDENT RESPONSE SYSTEM

Mr. Pornchai Korpraserttaworn	45010495
Mr. Larbboonek Kamolpimook	45010496
Mr. Akkradach Watcharapupong	Advisor
Asst. Prof. Thana Hongsuwan	Co-Advisor
Mr. Tanunchai Tripak	Co-Advisor
Academic Year 2005	

ABSTACT

Eventhough the computer security system is now much more powerful than the old days. It cannot be considered the perfect system anyway. Since the problems still exist, the reliable security system has to be ready for the unexpected events to occur. The system should be able to handle those at the time intrusion taking place as well as before and after the affairs in order to be able to make an incident response to such an event. The incident response mentioned includes knowing what the intruder has done to the system, detecting the effects to the system, recovering the system and gathering the information due to the legal issue.

This project purposes presenting a new method in computer security aiming at the effective way to response when there is an intrusion. All is done under UNIX environment.

กิตติกรรมประกาศ

ปริญญานิพนธ์ฉบับนี้จะไม่สามารถเสร็จสมบูรณ์ได้ถ้าไม่ได้รับคำแนะนำ คำเตือน
ทั้งหลายจากอาจารย์อัครเดช วัชรภูพงษ์ ผู้ช่วยศาสตราจารย์ธนา หงษ์สุวรรณ และอาจารย์ณัฐชัย
ตรีภาค คณะผู้จัดทำขอขอบพระคุณอย่างยิ่งสำหรับทุกสิ่งทุกอย่างที่ได้รับจากท่านทั้งสาม

นอกจากนี้ขอขอบคุณสถาบัน ภาควิชาวิศวกรรมคอมพิวเตอร์ และห้องวิจัยและพัฒนาการ
รักษาความปลอดภัยข้อมูล (ISAG) ที่ได้เอื้อเฟื้อสถานที่ให้คณะผู้จัดทำได้ทำการวิจัยและศึกษา
ขอขอบคุณเพื่อนๆ พี่ ๆ ห้อง ISAG ที่ได้ให้คำแนะนำและให้ความช่วยเหลือในยามที่ผู้จัดทำพบกับ
ปัญหาได้ดีเสมอมา

สุดท้ายต้องขอขอบคุณบิดา มารดาที่ได้ให้กำเนิด คอยสั่งสอน ให้การสนับสนุนการศึกษา
และเป็นกำลังใจในการศึกษาเล่าเรียนเสมอ นับเป็นพระคุณอย่างยิ่ง

นายพรชัย กอประเสริฐถาวร

นายลาภบุญเอก กมลพิมุกด์

สารบัญ

หน้า

บทคัดย่อภาษาไทย	I
บทคัดย่อภาษาอังกฤษ	II
กิตติกรรมประกาศ	III
สารบัญ	IV
สารบัญตาราง	VI
สารบัญภาพ	VII
บทที่ 1 บทนำ	1
1.1 บทนำ	1
1.2 วัตถุประสงค์ของโครงการ	1
1.3 ประโยชน์ที่คาดว่าจะได้รับ	1
1.4 ขอบเขตของโครงการ	2
1.5 เนื้อหาของรายงาน	2
บทที่ 2 ทฤษฎีที่เกี่ยวข้อง	3
2.1 บทนำ	3
2.2 ทฤษฎีการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย (Incident Response)	3
2.3 รูปแบบและพฤติกรรมของผู้บุกรุก	10
2.4 ระบบตรวจจับผู้บุกรุก	12
2.4.1 Host based IDS	13
2.4.1.1 Unix logs (syslogd)	14
2.4.1.2 syslog-ng	20
2.4.1.3 Tripwire	21
2.4.1.4 Samhain	22
2.4.2 Network based IDS	23
2.4.2.1 Snort และ Snort-Inline	24
2.5 Internet Protocol Security (IPSec)	25

สารบัญ

หน้า

2.6 Forensics	28
2.6.1 Computer Forensics	28
2.6.1.1 พื้นฐานสำคัญที่ใช้ในการ ตรวจสอบการละเมิดสิทธิ์ และหาข้อมูล	28
2.6.2 Network Forensics	32
บทที่ 3 การออกแบบและพัฒนา	36
3.1 บทนำ	36
3.2 การออกแบบฮาร์ดแวร์	36
3.3 การออกแบบซอฟต์แวร์	37
3.3.1 Sensor	37
3.3.2 Forensic	40
3.3.3 Recovery	48
บทที่ 4 การทดสอบและผลการทดสอบ	52
4.1 บทนำ	52
4.2 การทดสอบที่ 1 การเก็บข้อมูลทางด้านเครือข่าย	52
4.3 การทดสอบที่ 2 การเก็บข้อมูลจากเครื่องคอมพิวเตอร์	54
4.4 การทดสอบที่ 3 การแจ้งเตือนและการวิเคราะห์	56
4.5 การทดสอบที่ 4 การกู้คืนระบบ	56
4.6 การทดสอบที่ 5 การจำลองสถานการณ์จริง	57
บทที่ 5 บทสรุป	68
5.1 วิเคราะห์และสรุปผลการทดสอบ	68
5.2 ปัญหาและอุปสรรค	68
5.3 แนวทางการประยุกต์และการพัฒนา	69
บรรณานุกรม	70

สารบัญตาราง

ตารางที่	หน้า
2.1 แสดงค่า facility และความหมาย	14
2.2 แสดงค่า priority และความหมาย	15
2.3 แสดงรายชื่อซอฟต์แวร์ที่ใช้ syslog	18

สารบัญรูปภาพ

รูปที่	หน้า
2.1 ขั้นตอนการตอบสนองต่อเหตุการณ์ละเมิดความปลอดภัย	4
2.2 แสดงตัวอย่างการหา checksum	22
2.3 รูปแบบการใช้งาน IPsec	25
2.4 Authentication Header	27
2.5 Encapsulated Security Payload	27
3.1 แสดงโครงสร้างของระบบที่ได้ทำการออกแบบไว้	36
3.2 แสดงกับรับส่งข้อมูลผ่าน IPsec	38
3.3 แสดงการเก็บข้อมูลจากโปรแกรม Syslog	38
3.4 แสดงการเก็บข้อมูลลงฐานข้อมูล	38
3.5 แสดงการส่งข้อมูลไปเก็บยังเครื่อง Log Server	39
3.6 แสดงขั้นตอนการทำงานของโปรแกรม Iptables และ โปรแกรม Snort	40
3.7 แสดงหน้าค้นหาข้อมูลของเครือข่าย	42
3.8 แสดงข้อมูลทางเครือข่าย	42
3.9 แสดงข้อมูล data payload	43
3.10 แสดงหน้าค้นหาไฟล์ที่โดนละเมิดความปลอดภัย	44
3.11 แสดงผลรายชื่อไฟล์ทั้งหมดที่โดนละเมิดความปลอดภัย	45
3.12 แสดงข้อมูลของไฟล์ที่โดนละเมิดความปลอดภัย	45
3.13 แสดงรายชื่อผู้ใช้ที่ใช้งานระบบอยู่ในเวลาเดียวกันกับเวลา ที่ไฟล์ /etc/passwd โดนละเมิดความปลอดภัย	46
3.14 แสดงการกู้คืนไฟล์ที่โดนละเมิดความปลอดภัย	46
3.15 แสดงหน้าสำหรับค้นหาข้อมูลจากล็อกไฟล์	47
3.16 แสดงข้อมูลทั้งหมดจาก ล็อกไฟล์	47
3.17 แสดงการค้นหาผู้ใช้งานที่ใช้ระบบในช่วงเวลาที่กำหนด	48
3.18 แสดงรายชื่อผู้ใช้งานที่ใช้งานระบบในช่วงเวลาที่กำหนด	48
3.19 แสดงคำสั่งของผู้ใช้ detector ในช่วงเวลาที่กำหนด	48
3.20 แสดงหน้า Snapshot Management	50
4.1 แสดงการแสดงผลโดยที่ยังไม่มีการเริ่มเก็บข้อมูล	52
4.2 แสดงข้อมูลที่ได้หลังจากทำการเก็บข้อมูลจากเครือข่าย	53

สารบัญรูปภาพ (ต่อ)

รูปที่	หน้า
4.3	แสดงการเข้ารหัสและตรวจสอบความถูกต้องของข้อมูลโดยผ่าน IPsec54
4.4	แสดงการแสดงผลโดยที่ยังไม่มีการเริ่มเก็บข้อมูล55
4.5	แสดงข้อมูลที่ได้หลังจากทำการเก็บข้อมูลจากเครื่อง Response wall55
4.6	แสดงการพิสูจน์ตนเพื่อเข้าสู่ระบบ57
4.7	แสดงข้อมูลในขณะที่ระบบยังไม่ถูกละเมิดความปลอดภัย58
4.8	แสดงข้อมูลหลังจากที่ระบบถูกละเมิดความปลอดภัย58
4.9	แสดงข้อมูลที่บ่งบอกถึงการเปลี่ยนแปลงที่ไฟล์ /etc/passwd59
4.10	แสดงข้อมูลที่บ่งบอกถึงเวลาที่ไฟล์ /etc/passwd โดนเปลี่ยนแปลง59
4.11	แสดงข้อมูลที่บ่งบอกการใช้งานระบบ59
4.12	แสดงข้อมูลที่บ่งบอกการใช้คำสั่งของผู้ใช้งานระบบ60
4.13	แสดงข้อมูลที่บ่งบอกรายละเอียดของการใช้คำสั่งของผู้ใช้งานระบบ60
4.14	แสดงผลของระบบจากการหาข้อแตกต่างของไฟล์ที่พบการเปลี่ยนแปลง61
4.15	แสดงการหาข้อแตกต่างของไฟล์ที่โดนเปลี่ยนแปลง61
4.16	แสดงการหาข้อแตกต่างของไฟล์ที่โดนเปลี่ยนแปลง62
4.17	แสดงการเพิ่มไฟล์เข้าไปในระบบการ Recovery63
4.18	แสดงการเข้าไปตรวจสอบค่าหลังจากที่ได้ทำการกู้คืนระบบ63
4.19	แสดงการตั้งค่าช่วงเวลาของการเก็บ Snapshot64
4.20	แสดงการ Log in เข้าใช้บริการยังเครื่องเป้าหมาย65
4.21	แสดงการทดสอบการใช้คำสั่ง sudo65
4.22	แสดงการเข้าไปแก้ไขข้อมูลในไฟล์ /etc/passwd66
4.23	แสดงการเข้าไปดูข้อมูลในไฟล์ /var/log66
4.24	แสดงข้อมูลในไฟล์ /var/log หลังจากที่ได้โดนแก้ไขแล้ว67